Thesis, October 2026

Investing in the Harness

My thesis on applied AI, governance and sovereignty

By Marc Taverner October 2026

When I started in internet infrastructure, most people assumed the value would sit with whoever owned the fastest pipe. It didn't. Bandwidth got cheaper every year, and the money moved to the people who built the things that made a connection useful and trustworthy for a particular business: payments, identity, security, the dull plumbing of who is allowed to do what. I spent the next part of my career in collaboration platforms and then in digital assets, and I watched the same pattern repeat. The raw capability commoditises. The control layer around it does not.

I believe applied AI is following that pattern, and faster than most investors are pricing in.

The model is not the asset

Foundation models have become broadly interchangeable for most business work. Per token prices keep falling while volume keeps growing, and the gap between the best model and the third best model on any given task is now measured in months, not years. Most serious buyers I speak to already run more than one model and choose by price and fit for each task.

That has a simple consequence for where I put money. If the model is a commodity input, a company whose value is really just the weights it trained, or the fine tune it sits on, is renting its advantage from someone who can reprice it at will.

The durable asset is what I call the harness. It is everything built around a model to make it reliable inside one particular business. Swap the model and a good harness should keep working.

What I mean by the harness

I think about the harness as six layers.

1. **Context** is the documents, history and retrieval that give an agent the knowledge of this business rather than the internet in general.
2. **Policy** is what the agent may and may not do, written down in a form a machine can enforce.
3. **Process** is the workflows, tools and orchestration that turn a single answer into a piece of finished work.
4. **Evaluation** is the test sets, graders and traces that define what a correct answer looks like in this particular business.
5. **Feedback** is how a correction made today improves the system tomorrow.
6. **Identity** is who the agent is, who it acts for, and what it is entitled to touch.

These layers are not equally investable. Context, in the narrow sense of retrieval and memory, has become a free platform feature across five major platforms in roughly eighteen months. I would not fund it as a standalone product today, however good the team.

Evaluation and identity are a different story. The definition of a correct answer in an insurer's claims process, or a bank's onboarding flow, is specific to that organisation. It is also exactly the thing an auditor, a regulator or an insurer will ask to see when an agent gets something wrong. Identity is the question every security team is now being asked by its board: which agents are running, on whose authority, with which credentials, and who can switch them off.

What I want to fund is the governance, lineage and evaluation infrastructure that works across clouds and across model vendors, produces evidence that a regulator or auditor will actually accept, and is sold to the security and compliance buyer. One condition matters more than any other. The customer keeps ownership of its own evaluation content and test cases. That is the asset. The vendor's job is to make it usable, not to hold it hostage.

Leasehold and freehold

There is a property analogy I keep coming back to. A fine tune on a closed frontier model is a leasehold, not a freehold. OpenAI has already closed self serve fine tuning to new customers, and from 6 January 2027 even its existing customers can no longer train new fine tunes. The ones they already have keep running only until OpenAI retires the model underneath. On Azure, fine tuned weights cannot be downloaded and they expire on a published schedule. You paid for the improvement, and you still don't own it.

A company's own evaluation suite, its written policies and its curated context are different. They sit on its own systems. It holds them by possession rather than by contract, which is the only form of real ownership this market currently offers.

Whether that harness genuinely survives a change of underlying model is something I am treating as a thesis to test, not a fact to assert. I think it does, mostly. I don't know yet how much rework is involved in practice. So I am measuring it myself. I am building my own personal AI agent, a genuinely personal assistant that does my digital work while keeping my memory, context and data under my control rather than captured inside one vendor's platform. Every so often I swap the underlying model and record two things: how much rework the change needs, and whether a fixed evaluation suite catches the resulting drift before it causes a real mistake.

Who actually pays

Here is the commercial reality I have learned to respect. Individuals will not pay for privacy they can get for free. The large majority of password manager and VPN users sit on the free tier. I like consumer privacy as a cause. I don't back it as a business.

Enterprises are different because they have obligations, not preferences. They have audit requirements. They have data residency law. They carry contractual liability for what an autonomous agent did on their behalf. Nobody buys a compliance control for fun; they buy it because the alternative is a fine or an uninsurable risk. That is the buyer I want the companies I back selling to.

Revealed enterprise spend on securing AI is still a small fraction of total AI spend. Some people read that as a ceiling. I read it as an early category. Cloud security, identity and endpoint protection all started as rounding errors on the budget of the thing they protected, and each became a large market once something went wrong publicly and the obligation caught up with the technology.

I also want to be honest about where the independent opportunity is narrower than the headline suggests. An enterprise that runs everything through one model vendor will simply buy controls from that vendor. The opening for an independent company is in three places. The first is enterprises running agents across several clouds and several model vendors, where no single vendor's tooling can see the whole picture. The second is enterprises with real jurisdictional exposure, where the incumbent vendor is itself part of the risk being managed. The third is any situation that needs evidence for a genuinely independent third party, such as an auditor or an insurer, who will not take a vendor's word about its own product.

That last point is the heart of it. Neutrality is the product.

What actually works for privacy today

A great deal of money is being raised on privacy technology that does not yet do what the pitch says, at least not for AI inference.

Confidential computing works. It runs a workload inside a secure hardware enclave, so that even the cloud operator cannot see the data while it is being processed, and it can prove to the customer which code ran. It is in production at the major clouds and on current GPUs, and the performance overhead has become small. Keeping sensitive context on the client side and sending only what a task needs also works, and it costs nothing.

Fully homomorphic encryption and multi party computation are not practical for AI inference at any meaningful scale today. They are serious research fields. They are not where I would put a privacy guarantee for a production agent in 2026.

Zero knowledge proofs are the most frequently misapplied of all. A zero knowledge proof shows that a computation was carried out correctly. It does not let a model compute on data it cannot see. When someone pitches me zero knowledge privacy for AI, my question is simple: who holds the unencrypted data while the proof is being generated? The answer usually ends the conversation.

Simple tokenisation or data masking is not enough on its own either. Published re identification studies show it can often be reversed.

What works today is a combination. Confidential computing for workloads that need cloud scale. Client held context, so the sensitive material never leaves the customer's control by default. Local inference on open weight models for the genuinely sensitive fraction of the work. Everything else runs on whichever frontier model is best and cheapest that month, and a cross vendor evaluation suite governs the whole arrangement so the customer knows when quality moves. None of that needs a breakthrough. It needs good engineering and someone neutral to stitch it together.

Europe is the long dated opportunity

Most of what I have described is a race against the platforms' release schedules, and I am realistic about who usually wins that race. There is one opportunity that does not depend on winning it, because it is created by law and politics rather than by a product roadmap. That is European sovereignty.

AWS's European Sovereign Cloud reached general availability in January 2026. It is built around a new entity that is physically and legally separate from the rest of AWS, anchored by a region in Brandenburg, with a German investment commitment of more than seven billion euros and named early customers. At the same time, Mistral AI is positioning itself as Europe's own independent sovereign AI champion while also being a launch partner on that same American

hyperscaler's sovereign cloud. I don't see a contradiction there. I see a market still forming its coalitions, which is exactly when the infrastructure that sits between the parties gets built and gets valuable.

The legal pressure is durable. The EU Data Act's provisions on cloud switching and egress fees take full effect from January 2027, which makes it materially easier for a European enterprise to move workloads and materially harder for a vendor to lock them in. The EU AI Act creates real obligations around fine tuning and deployment that a vendor based outside Europe cannot simply contract its way around. These obligations do not get commoditised by a feature launch. They get stronger as enforcement starts.

I don't want to fund another sovereign cloud. What I want to fund is the governance, lineage and evaluation layer that lets a European enterprise prove to a regulator that its agents ran where they were supposed to, under the law that actually applies, across infrastructure that mixes American hyperscalers, European model providers and open weight models running on its own hardware. Proof is the product.

Two shapes of company

I back two different shapes of company, and I am explicit with founders about which one I think they are building.

The first shape is near term. These are companies built to be acquired by identity and security incumbents who need the capability quickly and cannot build it in time. Okta, CrowdStrike, Cisco, SailPoint and Cyera are the kind of buyer I have in mind. Recent comparable acquisitions in security categories have mostly landed between two hundred million and one billion dollars, not in the tens of billions. A focused team with a sharp product, a handful of reference customers and clean integration with the acquirer's stack can deliver an excellent outcome on a modest amount of capital. That is not enough to build an Okta. It is enough to build something Okta wants.

The second shape is longer duration. These are companies whose advantage is genuine neutrality across clouds and model vendors, or genuine jurisdictional specificity, most often European. They do not need to win a sprint against a hyperscaler, because the thing protecting them is law and neutrality rather than a feature lead. They take longer and need more patient capital. They are also the ones that can become durable independent businesses.

Both shapes are good. What I won't do is fund a company that thinks it is the second shape while building the first.

The companies I want to back and advise

The first area is agent governance, identity and audit, and it has moved fast. Onyx Security is building controls for how AI agents operate inside the enterprise, so a security team can see and govern what those agents actually do. Oasis Security came out of the non human identity problem, the service accounts, keys and tokens that now outnumber human users in most organisations, and extended that into managing the access that AI agents are granted. Cyera agreed to buy it for around a billion dollars in July 2026, which is the first shape of company I described above working exactly as intended. Keycard is working on identity and access built specifically for agents, the question of who an agent is and what it may touch, designed in from the start rather than retrofitted from human login systems. AIUC approaches the same problem from the insurer's side, setting a standard for AI agent risk and tying it to underwriting, which is precisely the independent third party I described earlier. GitGuardian built its name on detecting leaked secrets in code and has become a natural home for the credentials sprawl that agents create.

These are the right shape for a simple reason. Each sits on an obligation rather than a preference, each is most useful when it sees across vendors, and each produces evidence someone other than the vendor will rely on. They have been funded at seed through Series B. None of them yet discloses meaningful revenue publicly. I say that as an observation, not a criticism. It tells me the category is still being underwritten on thesis and on team, which is when the best entry points exist and when judgement matters most.

Evaluation and observability infrastructure is the second area. Braintrust and Galileo are good examples of what I mean: tooling that lets a company define what a correct answer looks like in its own business, trace every agent decision, and keep that evaluation suite as its own asset regardless of which model sits underneath. This is the layer that makes the leasehold and freehold distinction real for a customer.

Digital identity wallet middleware is the third. Europe is rolling out the EU Digital Identity Wallet, and someone has to connect that to the agents acting on a person's or a company's behalf. Procivis, the Swiss firm building wallet and credential infrastructure already used in government rollouts, is the type of company I mean: the plumbing that lets an agent present verified credentials and act within a mandate the human has actually granted.

Post quantum crypto agility is the fourth. Every signed credential, every agent identity and every audit log I have described rests on cryptography that will need replacing over the next decade. PQShield, the Oxford firm selling post quantum migration tooling to enterprises and silicon vendors, represents what I look for here: not a new algorithm, but the ability for an enterprise to find, inventory and swap its cryptography without rebuilding its systems. Regulators have already set migration timelines, so this is an obligation with a date attached.

Confidential computing and attested inference is the fifth. Anjuna Security is building the kind of product I described in the privacy section: running workloads, AI inference included, inside hardware attested enclaves across any cloud, and giving the customer a cryptographic receipt showing which model ran, on which hardware, against which data. That receipt is exactly the sort of evidence an auditor can accept.

European sovereign AI infrastructure is the sixth. OVHcloud is the right shape not because it competes with the hyperscalers on scale, but because it gives European enterprises a credible, jurisdictionally clean option for the part of their work that has to stay under European law. Its acquisition of Dragon LLM and the sales organisation it has built around sovereign demand are the tell. It is building the plumbing, not just the marketing.

Across all six, the common thread is the same. The company makes the harness portable, provable or protected, and it sells to someone who is obliged to buy.

What I decline

I find it saves everyone time to be clear about this up front.

- Model companies, and anything whose value is really just the underlying weights.
- Consumer memory and consumer data vault products. The platforms now give this away.
- Anything relying on fully homomorphic encryption, multi party computation or zero knowledge proofs as the actual privacy mechanism for AI inference. They don't work at this scale yet.
- Anything whose entire differentiation is a feature already on a hyperscaler's public roadmap.
- Any company that wants to own the customer's evaluation data and test cases rather than letting the customer keep them. That is lock in dressed up as a sovereignty pitch, and I won't back it.

What would change my mind

There are two open questions I can't yet answer, and they are the two that would move me most.

The first is portability in practice. I have not yet found a single named enterprise that has publicly credited the portability of its own evaluation harness with letting it switch its primary AI vendor. I believe it is happening quietly. I would like to see it on the record. If, over the next year or so, large buyers start citing their own evaluation suites as the reason a model switch took weeks rather than quarters, the freehold argument becomes a proven commercial one. If

switches keep happening and nobody credits the harness, I will need to rethink how much of this value really sits with the customer.

The second is who captures the spend. I don't yet have good data on whether enterprises buy this kind of governance tooling from independent companies, or simply absorb it into contracts they already hold with their incumbent security vendors. If independent companies keep winning standalone budget lines, the second, longer duration shape gets much more attractive. If the spend folds into existing Okta, CrowdStrike or Microsoft agreements, the first shape is the main event and I will size my positions accordingly. The signal I'm watching is simple: line items on purchase orders, and who the cheque is made out to.

Where I have landed

My underlying convictions haven't changed since I first started writing about this. I care about portability. I care about sovereignty, at the personal level and at the national level. I care about privacy, and I want agentic AI that is genuinely useful and genuinely trustworthy, not one or the other.

What has changed is how precisely I can say where those convictions meet a cheque I'm willing to write. I back companies that own the harness rather than the weights, that sell to an obligation rather than a preference, and that compete on neutrality rather than secrecy. I back them in Europe where the law gives them a long runway, and anywhere an independent party needs evidence a vendor can't provide about itself.

If you're building one of those companies, or investing in them, or writing the rules they will have to prove they follow, I'd like to talk.